IDENTIFICATION AND AUTHENTICATION

WyIT - 3006

PURPOSE: To ensure that only properly identified and authenticated users and devices are granted access to CIO resources in compliance with IT security policies, standards, and procedures.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

III. EXCEPTIONS

Any exceptions provided to the following policy must abide by the WyIT - 3002 - Security Exception Request policy.

IV. IDENTIFICATION AND AUTHENTICATION

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure that information systems uniquely identify and authenticate users or processes acting on behalf of the State.
- Ensure that information systems implement multifactor authentication for network access to privileged accounts where technically possible.

- Ensure that information systems implement multifactor authentication for network access to non-privileged accounts where technically possible.
- Ensure that information systems implement multifactor authentication for local access to privileged accounts where technically possible.
- Ensure that information systems implement replay-resistant authentication mechanisms for network access to privileged accounts.
- Ensure that information systems implement multifactor authentication for remote access to privileged and non-privileged accounts such that one of the factors is provided by a device separate from the system gaining access and the device utilizes a cryptographic strength mechanism that protects the primary authentication token (secret key, private key or one-time password) against compromise by protocol threats including but not limited to, eavesdropper, replay, online guessing, verifier impersonation and man-in-the-middle attacks.
- Ensure that information systems uniquely identify and authenticate non-affiliate users or processes acting on behalf of non-affiliate users.

V. DEVICE IDENTIFICATION AND AUTHENTICATION

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure that information systems uniquely identify and authenticate all devices before establishing a network connection.

VI. IDENTIFIER MANAGEMENT

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure that applicable agencies and/or affiliates manage information system identifiers by receiving authorization from authorized agency security liaisons to assign an individual, group, role, or device identifier (i.e., Active Directory User-ID).
- Select an identifier (User-ID) that identifies an individual, group, role, or device.
- Assign the identifier (User-ID) to the intended individual, group, role, or device.

VII. AUTHENTICATOR MANAGEMENT

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Manage information system authenticators (i.e. passwords, PINs, hardware tokens, etc.) by verifying, as part of the initial authenticator distribution, the identity of the individual, group, role, or device receiving the authenticator.
- Establish initial authenticator content for authenticators defined by the organization.
- Ensure that authenticators have sufficient strength of mechanism for their intended use.
- Establish and implement administrative procedures for initial authenticator distribution, for lost/compromised or damaged authenticators, and for revoking authenticators.
- Change default content of authenticators prior to information system installation.
- Establish minimum and maximum lifetime restrictions and reuse conditions for authenticators.
- Protect authenticator content from unauthorized disclosure and modification.
- Require individuals and devices to implement specific security safeguards to protect authenticators.
- Change authenticators for group/role accounts when membership to those account changes.
- Ensure that information systems for password-based authentication enforce minimum password complexity that must not contain the user's entire Account Name value or entire Full Name value.
- Ensure the password management features established in the “General Security - Acceptable Use; Password Standards” are met.
- Ensure that the information system, for PKI-based authentication, validates certifications by constructing and verifying a certification path to an accepted trust anchor including checking certificate status information.
- Enforce authorized access to the corresponding private key.
- Map the authenticated identity to the account of the individual or group.
- Implement a local cache of revocation data to support path discovery and validation in case of inability to access revocation information via the network.
- Ensure that the information system, for hardware token-based authentication, employs mechanisms that satisfy industry best practices.

VIII. AUTHENTICATOR FEEDBACK

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure that information systems obscure feedback of authentication information during the authentication process to protect the information from possible exploitation/use by unauthorized individuals.

REFERENCES: This policy has no supporting references to websites, other policies, or federal or state statutes.

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	**SUBMITTED BY**	**APPROVED BY**	**APPROVED BY DATE(S)**	**EFFECTIVE DATE**
June 2024	ETS Governance, Risk and Compliance	Public Comment Period	05/10/2024 - 05/24/2024	June 2024

REVISIONS		
LAST REVISION DATE	**LAST REVISED BY**	**LAST APPROVED BY**

REVIEWS		
LAST REVIEW DATE	**LAST REVIEWED BY**	**NEXT REVIEW DATE**